

30-day Incident Report

Reporting organisation: QuickSilver Materials

Sector: Chemicals and Production Distribution

Incident ID: QSM-2026-SQLI-001

Reporting recipient: Myndigheten för civilt försvar (MCF)

Report type: Final report under the Cybersecurity Act (NIS2)

Date: 2026-06-31

1. Incident overview

Between 11–13 May 2026 the organisation identified suspicious activity targeting the company's publicly accessible web services. The investigation identified repeated login-related requests, abnormal API interaction, and subsequent access to sensitive customer data. The observed behaviour is consistent with suspected SQL injection, access control breach through elevated privileges and, eventually, data extraction.

No evidence related to damage to the company's system, operations and financial assets as a result of the attack has been found. The incident doesn't indicate lateral movement within the network and system itself nor does it point to external damage outside of personal data violation.

2. Timeline summary

11 May 2026

Initial suspicious activity was detected through Wazuh-generated alerts originating from nginx container access logs. The activity consisted of repeated requests targeting authentication and admin-related API endpoints combined with increased number of HTTP 400 and 500 warnings from the same IP.

12 May 2026

The activity became more focused around login attempts, particularly /rest/user/login and access-related APIs. Multiple successful and failed authentication responses were recorded within short intervals indicating possible manipulation of access logic.

13 May 2026

Authenticated sessions were observed accessing stored personal customer data including address, payment information, delivery records, wallet information and administration configuration functions. Following all collected evidence, the activity was classified as suspected unauthorized privileged access.

3. Affected systems and services

The following systems were directly affected during the incident:

- QuickSilver Materials web services
- nginx container
- admin account serving as a primary attack and pivot surface
- API endpoints associated with authentication and user management
- sensitive customer data endpoints as an aftermath of the incident

The following categories of information were potentially exposed during the activity:

- customer account information
- address records (globally and individually)
- stored credit card details
- delivery information
- wallet balance information
- admin configuration data

4. Root cause assessment

The investigation determined that the most probable root cause was insufficient input validation and weak access-control enforcement within the web services design.

Observed request patterns strongly indicate attempted SQL injection assuming access intent. Following successful login, during the same session the aggressor was able to access multiple categories of sensitive information and admin endpoints without evident privilege separation.

The investigation also uncovered inadequate logging practices. While nginx access logs successfully recorded HTTP responses, no logs with purpose of recording contents or backend activity were set. This significantly reduced the ability to directly confirm the method used or reliably reconstruct the chain of events during the attack.

In addition the testing on the affected company systems unequivocally confirmed its lack of ability to detect corruptive activity as it was happening in real time.

The methods used and the confirmed nature of the attack remain inconclusive.

5. Impact assessment

The primary impact of the incident relates to unauthorized access to private customer and financial data and its likely extraction. While no evidence of permanent data modification or destruction exists, the incident represents a significant confidentiality breach.

End-investigation yielded no evidence pertaining to following:

- malware deployment
- compromise of the company's network and main system
- lateral movement outside of the affected web endpoints
- ransom, extortion or sabotage attempts
- harassment of the users and customers in relation to extracted data

6. Actions taken

Following identification of the suspicious activity, the organisation initiated the following containment measures:

- continuous monitoring of nginx logs and Wazuh alerts
- preservation of all relevant evidence in form of logs and artefacts
- review of all API behaviour
- inspection of all containers metadata and filesystem state
- analysis of user behaviour and access patterns
- verification of absence of broader compromise and analysis of the post-attack threats
- immediate communication with the all affected parties, issued police report and compliance with NIS2 reporting obligation

The affected containers were isolated for investigative purposes and additional monitoring was maintained throughout the review period.

7. Recovery status

Upon the third day of the attack, no more ongoing activity of any kind has been seen from the same IP within the monitored environment throughout the conclusion of this investigation.

The affected services were reviewed and prepared for corrective security measures. Additional monitoring efforts were increased following the incident to identify potential recurrence of the attack.

No operational reinforcement in regards to company's network and systems safety were implemented.

8. Preventive and corrective measures

The organisation identified the following corrective actions and long-term improvements:

- implementation of parameterised backend code
- strengthened server-side input validation
- separation of admin-governed controls from standard user APIs
- improved access-control enforcement
- expansion of in-depth forensic logging capabilities
- access to in depth forensic tools allowing total incident reconstruction
- monitoring of abnormal authentication patterns
- alerting on access attempts involving admin-governed endpoints
- implementing system bridge between behaviour, login and sensitive data access

9. GDPR and personal data assessment

Because the activity involved access to customer and financial information, the incident was reviewed in parallel from a personal data protection perspective.

The organisation's Data Protection Officer function was informed during the investigation in order to assess whether the observed access met the threshold for notification obligations under GDPR.

All affected parties have been informed and advised on containment actions.

10. Final assessment

The incident demonstrated how weaknesses in authentication handling, insufficient access-control system and limited forensic logging can contribute to unauthorized access within company's web infrastructure.

The investigation demonstrated that web-level logging alone doesn't provide sufficient forensic evidence during web-based attacks, particularly where concrete payloads aren't captured.

The organisation considers the incident contained and closed at the time of this report. Long-term corrective measures and monitoring improvements have been implemented to reduce the likelihood and impact of similar incidents in the future.